

POLICY ON PRIVACY AND DATA PROTECTION

(JAN SAHAS SOCIAL EMPOWERMENT SOCIETY)

Disclaimer:

This document is intended solely for the internal use of JSSES and is not intended to be and should not be used by any other person or entity. No other person or entity is entitled to rely, in any manner, or for any purpose, on this document.

Copyrights:

All rights reserved. No part of this document may be reproduced or transmitted in any form and by any means without the prior permission of JSSES.

Version	2
Policy Owner:	TI and Human Resources Department
Date of first approval by Board:	November 2020
Review Schedule:	Annually by the Board
Date of most recent review:	April 2022
Date of next review:	April 2023

Table of Contents:

1.		Introduction	4
2.		Definitions	4
3.		Privacy Policy Objective	6
4.		Policy Coverage	6
5.		Applicable Laws & Regulations	6
6.		Collection of Personal Data	6
7.		Privacy principles	6
8.		Right of Data Subjects	8
9.		Privacy Specific Process	8
10.		Privacy organization and Governance	10
11.		Non-Disclosure & Confidentiality Agreements	10
12.		Grievances & Complaints Redressal	10
13.		Review and Amendments	10

1. Introduction

We at JSSES respect the personal data entrusted to us by our users, employees, contractors, vendors, and candidates, and we are committed to fair, transparent, and secure processing of personal data. This policy outlines how JSSES (hereafter referred to as 'the organization') collects, processes, and uses the personal data of users in compliance with applicable data privacy laws.

2. Definitions:

In this policy, unless the context indicates otherwise:

2.1. Product and Services: Products and services offered by the organization.

2.2. Data: A representation of information, facts, concepts, opinions, or instructions in a manner suitable for communication, interpretation, or processing by humans or automated means.

2.3. Data Subject: An individual whose personal data is processed by the organization or by another entity on behalf of the organization.

2.4. Personal Data: Any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.

2.5. Sensitive Personal Data (SPD): A special category of personal data that requires focused handling. Personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, genetic data, biometric data, data concerning health, or data concerning a natural person's sex life or sexual orientation. Sensitive personal data is a subset of personal data. Hence, wherever sensitive personal data is not mentioned separately in this document, it is deemed to be included under personal data. Consequently, all that is applicable to personal data is automatically applicable to sensitive personal data.

2.6. Processing: Any operation or set of operations performed on personal data or on sets of personal data. These include collection, receipt, recording, holding, structuring, storage, organization, adaptation or alteration, collation, updating, retrieval, consultation, use, disclosure by transmission, dissemination, or otherwise making available in any form, merging, linking, alignment or combination, restriction, erasure, degradation, or destruction. These could be performed by manual or automated means.

2.7. Party: Organizations or individuals that include, but are not limited to, service providers, suppliers, contractors, consultants, temporary staff, and others that provide their products and/or services or are otherwise associated with the organization.

2.8. Genetic Data: Personal data relating to the inherited or acquired genetic characteristics of an individual, which provide unique information about the physiology or health of that individual.

2.9. Biometric Data: Personal data resulting from specific technical processing relating to the physical, physiological, or behavioral characteristics of an individual, which allow or confirm the unique identification of that individual, such as facial images or fingerprint data.

2.10. Data Concerning Health: Personal data related to the physical or mental health of an individual, including the provision of healthcare services, which reveal information about his or her health status.

3. Privacy Policy Objective:

The objective of this policy is to:

- Create a Privacy-aware and responsible culture towards management of Personal Data (PD) processed by and on behalf of the organization.
- Identify and protect Personal Data as per applicable laws.
- Identify and manage the legal, regulatory and other obligations towards Privacy and Protection of Personal Data.
- To increase employee awareness of Data Privacy in general and of acceptable data handling practices and applicable requirements in relation to Personal Data.
- To set minimum standards pertaining to Data Privacy and Personal Data within the organization.
- Measure and review the effectiveness of the Privacy Posture within the organization

4. Policy Coverage:

This Policy applies to the organization and the users of this policy are all employees, permanent or temporary, and all contractors working on behalf of the organization regardless of their geographic location.

5. Applicable Laws & Regulations:

The organization shall adhere to and comply with all applicable laws, regulations and standards relating to data protection and privacy.

6. Collection of Personal Data:

The organization may collect Personal Data from Data Subjects in the following ways:

Directly:

- Where the Data Subject is aware of or cognizant of her Personal Data being collected. Such as when Data Subject is registering on the app and is knowingly providing the required Personal Data.
- Where the Data Subject may not necessarily be aware of or cognizant of her Personal Data being collected. Such as, when Data Subject interacts online with one of the organization's or an associated third party's digital property and various online identifiers and other Personal Data gets collected.

Indirectly:

Where the Data Subject's Personal Data is collected from third parties.

7.Privacy Principles:

The organization has adopted the following Privacy Principles based on its applicable legal and regulatory requirements as well as best practices in the Privacy domain.

7.1. Lawful Basis of Processing:

The organization shall process Personal Data of Data Subjects only on lawful grounds and after following the due process as laid down by applicable laws & regulations.

7.2. Privacy Notice:

The organization shall make a Privacy Notice(s) available to its Data Subjects which provides information on the Personal Data processing practices followed by the organization. The placement, timing, content and mode of presentation or delivery of the Privacy Notice(s) will be as per the requirements of the applicable laws and regulations.

7.3. Consent:

The organization shall obtain consent from Data Subjects while collecting Personal Data, wherever consent is relied upon as legal basis for processing Personal Data.

Data Subjects shall, at any time during the lifecycle of their association with the organization or later, if applicable, have an option to withdraw any consent provided earlier. Such individuals shall be informed of the consequences of denying or withdrawing consent including the ability or inability of the organization to process transactions or deliver products and services upon withdrawal. In such case of withdrawal of consent, the organization shall have the option of not providing the product or service under consideration.

7.4. Choice:

The organization should provide Data Principals, wherever appropriate, with mechanisms to exercise choice in relation to the collection and processing of their Personal Data.

7.5. Purpose Limitation:

The organizations shall collect Personal Data for specific, explicit and legitimate purposes only. The organization shall process Personal Data only for the purpose(s) it is collected for as mentioned in the Privacy Notice.

7.6. Data Minimization:

The organization shall collect only that Personal Data from Data Subjects which is adequate, relevant and limited to the purposes for which it is to be processed.

7.7. Storage Minimization:

The organization shall retain Personal Data for only as long it is required for the fulfilment of the purpose(s) of processing and/or required by any applicable laws and regulations. The organization shall take reasonable steps to destroy or permanently de-identify Personal Data beyond this period.

7.8. Accuracy

The organization shall take reasonable steps to ensure that the Personal Data it collects, and processes is complete, accurate and up to date. The organization shall provide appropriate and adequate mechanisms to Data Subjects to communicate any changes or corrections to the Personal Data provided by them and have the same corrected or amended following due

process. The organization shall further ensure that the requisite modifications are communicated to applicable third parties with whom the data has been shared.

7.9. Disclosure:

The organization shall ensure that a check is made to confirm that there are legal and/or regulatory grounds for disclosing any information to a third party. Where such disclosure is required, the same shall be done after following due process laid down by the applicable laws in respective geographies.

The organization shall ensure that only the minimum amount of Personal Data necessary is disclosed to third parties.

7.10. Transfer:

The organization shall transfer Personal Data to external third parties or to external geographies, even within the organization, only if permitted by applicable laws and regulations.

The organization shall transfer Personal Data to only those third parties who have similar levels of Data Protection and Privacy controls as the organization.

Where Personal Data is being transferred across geographical boundaries, the organization shall comply with the requirements of applicable laws and regulations of the host and destination jurisdiction(s) in relation to the transfer.

7.11. Security:

The organization shall make its best efforts to ensure that all the Personal Data it processes is kept secure using appropriate technical and organizational measures including necessary policies, processes and controls. The organization shall implement & maintain applicable information security standards and frameworks as required by applicable laws and regulations.

7.12. Accountability:

The organization shall be accountable towards its Data Subjects for ensuring the Privacy of the Personal Data it processes as laid out in this policy.

8.Rights of Data Subjects

The organization is committed to provide its Data Subjects with all applicable rights as mandated by applicable laws & regulations. The organization shall implement relevant mechanisms, processes and procedures to facilitate these rights to its Data Subjects.

9.Privacy Specific Processes

The organization shall establish and update necessary processes & procedures to facilitate the establishment and management of the requirements of this Privacy Policy. This includes the following:

9.1. Information Classification of PD and SPD:

All Personal Data (PD) and Sensitive Personal Data (SPD) shall be categorized as 'Confidential' information as per the Information Security Policy of the organization. All policies, processes and controls applicable to the above categorization shall automatically be applicable to Personal Data & Sensitive Personal Data.

9.2. Personal Data Inventory Management:

The organization shall create a Personal Data Inventory to enable the organization in getting the requisite visibility over the Personal Data processed by it. This inventory shall be kept up-to-date and reviewed on a periodic basis.

9.3. Personal Data Purpose and Usage:

The organization shall document the purpose(s) of processing each Personal Data within each applicable process, function or relationship.

The organization shall establish necessary processes and controls to ensure that usage of Personal Data is limited to the purpose(s) for which it has been collected or processed.

9.4. Regulatory & Legal Intelligence for Privacy:

The organization shall establish necessary processes to ensure intelligence gathering of laws and regulations that impact Privacy at the organization. This would include any changes to existing laws and regulations as well as any new laws & regulations that emerge from time to time.

9.5. Contracts with Third Parties:

The organization shall establish necessary processes and controls to ensure its contracts with third parties incorporate requisite clauses and content to address the requirements of its Privacy program.

9.6. Cross Border Transfer of Personal Data:

The organization shall establish necessary processes and controls to ensure that necessary legal instruments are utilised as and where there is cross-border transfer of Personal Data and all associated obligations for the same are fulfilled.

9.7. Regulatory Bodies Management:

The organization shall establish necessary processes and controls to ensure that requisite reporting to and other obligations involving regulatory bodies specific to Data Privacy in each applicable jurisdiction are addressed.

9.8. Privacy Incident Management:

The organization shall establish necessary processes and controls to manage privacy incidents (also referred to as breaches).

Privacy Incidents are of two types: (i) Incidents pertaining to the security of Personal Data (ii) Incidents that do not pertain to the security of Personal Data.

Incidents pertaining to the security of personal data shall be addressed by the Security Incident Management process of organization. The Security Incident Management Process shall be appropriately modified to identify incidents specific to Personal Data and the take necessary measures required for the same.

In the event of a Personal Data Incident / Breach, the organization shall follow the processes laid down by applicable laws and regulations with regards to notification of the breach. Notification may be to the applicable Regulatory Authority, the Data Subjects impacted and any other entity as prescribed by the applicable law & regulation.

9.9. Privacy Awareness & Training:

The organization shall conduct Privacy Awareness and Training Programs for all its employees and other stakeholders as necessary.

9.10. Security of Personal Data:

The security of Personal Data shall be as addressed by the Information Security Policy and any other policies associated with the Information Security Policy. All processes and controls contained in those policies would be applicable.

9.11. Privacy Impact Assessment:

The organization shall carry out Privacy / Data Protection Impact Assessment (PIA/DPIA) of the processing activities as and when required, as mandated by applicable laws.

9.12. Privacy by Design and Default:

The organization shall incorporate Privacy by Design & Default wherever necessary in its processes and as required by applicable Laws and Regulations. This would include but would not be limited to the introduction of any new platform/service/product/location/function/process/relationship/other activity.

9.13. Records of Processing Activities/Record Keeping:

The organization shall keep records of all processing activities involving Personal Data in formats mandated by applicable laws & regulations. Upon request, these records would be disclosed to Data Protection Authorities, Auditors and any other entity as required by applicable Laws and Regulations.

9.14. Audit:

The organization shall have its Privacy Program audited by an internal audit team as well as by an independent data auditor annually or as may be required by applicable Laws and Regulations.

10. Privacy organization and Governance

The organization will establish an appropriate organization structure to design, implement and manage its Privacy Program.

The organization will establish the necessary governance mechanism(s) to ensure proper governance of its Privacy Program.

11. Non-Disclosure & Confidentiality Agreements

The organization shall incorporate requisite non-disclosure and confidentiality clauses in its agreements and/or contracts with employees as well as individuals external to The organization who are privy to the Personal Data being processed by The organization or its associated third parties.

12. Grievances & Complaints Redressal:

All Privacy-specific complaints shall be recorded and addressed without undue delay and as per any norms specified in applicable Laws and Regulations. The designated person or team at the organization shall redress the grievances expeditiously following due process

13. Review and Amendments:

This Privacy Policy is subject to change. Any changes would be communicated within 2 working days to the employees coming under the purview of this policy.

